Basic SSRF Against the Local Server

Lab Overview

- **Platform:** PortSwigger Web Security Academy
- **Vulnerability:** Server-Side Request Forgery (SSRF)
- **Difficulty:** Apprentice

Description

This vulnerability occurs when an application allows users to influence requests made by its server. In this lab, the attacker attempts to make the vulnerable application send a request to a service running on the local server.

Exploitation Steps

1. Identify the URL-fetching functionality in the application.
2. Intercept the relevant request using Burp Suite.
3. Send the request to Burp Repeater.
4. Modify the destination to use the loopback address, such as `127.0.0.1`, with the target specified by the lab.
5. Inspect the response and complete the lab objective.

Impact

- Unauthorized access to local services.
- Exposure of internal endpoints.
- Potential access to sensitive application functionality.

Remediation

- Restrict user-controlled URLs to trusted destinations.
- Block unauthorized loopback and private IP addresses.
- Apply firewall rules to restrict server-side requests.
- Secure internal services with proper authentication.

Conclusion

This lab demonstrates how SSRF can be used to target services running on the application server itself. Proper URL validation and network-level security controls help prevent these attacks.

Reference: PortSwigger Web Security Academy — SSRF